



Vulnerability Assessment and Penetration Testing Lab Report

of metasploitable vm

1. Overview

I planned to conduct a black-box Vulnerability Assessment and Penetration Testing (VAPT) lab exercise against target virtual machine **Metasploitable 2**. The assessment was performed from the perspective of an unauthenticated remote attacker with no prior knowledge of the target environments. The project follows a structured penetration testing methodology, including reconnaissance, scanning, enumeration, vulnerability assessment, controlled exploitation, and risk analysis. All testing activities were conducted within an authorized virtual lab environment for educational purposes and in accordance with ethical cybersecurity practices.

2. Objectives

- Conduct a black-box security assessment of the target virtual machines.
- Identify open ports, running services, and potential vulnerabilities.
- Perform controlled exploitation of confirmed vulnerabilities in an isolated lab.
- Evaluate the severity and potential impact of identified security weaknesses.
- Provide practical remediation recommendations to improve the security posture of the target systems.
- Document the complete assessment process, findings, and evidence in a professional VAPT report.

3. Methodology

The assessment followed the **Penetration Testing Execution Standard (PTES)** methodology, and all findings were rated using the **CVSS v3.1** scoring system.

PHASES	FUNCTIONS
1. Pre-Engagement Interactions	Scope, rules, authorization
2. Intelligence Gathering	Reconnaissance
3. Threat Modeling	What matters most to protect
4. Vulnerability Analysis	Scanning, finding holes
5. Exploitation	Actually breaking in
6. Post-Exploitation	What can you do now that you're in?
7. Reporting	Documenting everything

Tools used in mentioned phases:

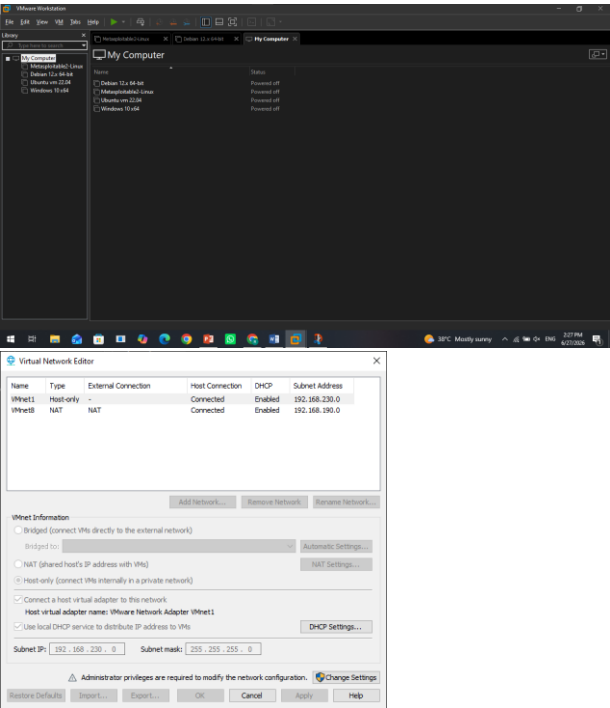
- **Intelligence Gathering:** Nmap, Netcat
- **Vulnerability Analysis:** Nmap,
- **Exploitation:** Metasploit, Netcat, manual commands
- **Post-Exploitation:** Meterpreter, LinEnum, hashdump
- **Reporting:** GitHub Markdown, CVSS v3.1 calculator

4. Lab-environment

components	details
Host Operating System	Windows 10
Virtualization Software	VMware Workstation
Attacker Machine	Kali Linux
Target Machine	Metasploitable 2
Network Configuration	NAT
Assessment Type	Black-box
Testing Environment	Isolated Virtual Lab

The assessment was conducted within an isolated virtual laboratory environment using VMware Workstation. Kali Linux served as the attacker machine, while Metasploitable 2 and Ubuntu were configured as target systems. The virtual machine was connected using both VMnet1 (Host-Only) and VMnet8 (NAT) networks. The Host-Only network provided an isolated environment for communication between the virtual machines, while the NAT network enabled controlled internet connectivity for updates and tool installation. This configuration provided a safe environment for performing vulnerability assessment and penetration testing without affecting production systems.

VM Ware network contains following machines:



Attacker's info:

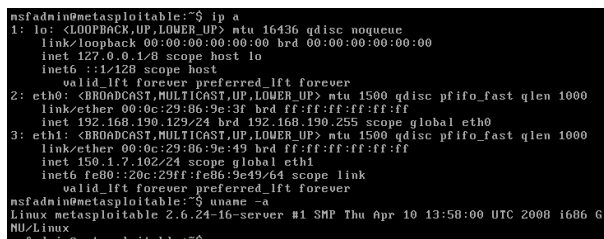
Use commands (hostname, hostname -I, cat /etc/os-release)



```
Session Actions Edit View Help
(kali123@kali123): ~
$ hostname
kali123
$ cat /etc/os-release
PRETTY_NAME="Kali GNU/Linux Rolling"
NAME="Kali GNU/Linux"
VERSION_ID="2025.3"
VERSION="2025.3"
VERSION_CODENAME=kali-rolling
ID=kali
ID_LIKE=debian
HOME_URL="https://www.kali.org/"
SUPPORT_URL="https://forums.kali.org/"
BUG_REPORT_URL="https://bugs.kali.org/"
ANSI_COLOR="1;31"
```

Target info (metasploitable 2)

Use commands (hostname, ifconfig, uname -a)



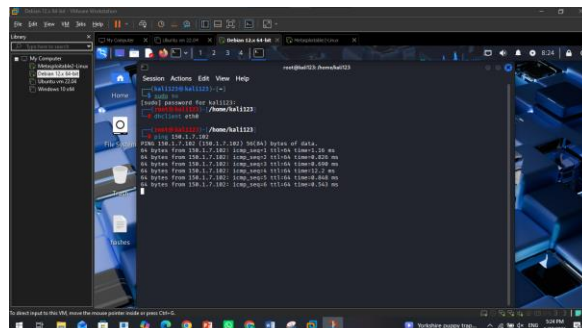
```
msfadmin@metasploitable:~$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 16436 qdisc noqueue
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        inet6 ::1/128 scope host
            valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast qlen 1000
    link/ether 00:0c:29:86:9e:3f brd ff:ff:ff:ff:ff:ff
    inet 192.168.190.129/24 brd 192.168.190.255 scope global eth0
3: eth1: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast qlen 1000
    link/ether 00:0c:29:86:9e:49 brd ff:ff:ff:ff:ff:ff
    inet 150.1.7.102/24 scope global eth1
    inet6 fe80::20c:29ff:fe86:9e49/64 scope link
        valid_lft forever preferred_lft forever
msfadmin@metasploitable:~$ uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 G
NU/Linux
```

5. Reconnaissance (Scanning)

a) Network Connectivity Verification

Commands used: ping 150.1.7.102

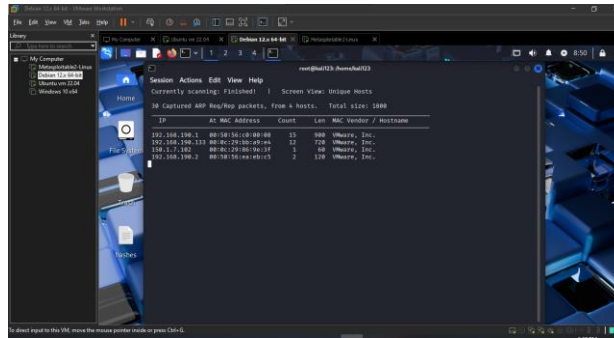
Metasploitable:



Targets is reachable

b) Host Discovery

Commands used: netdiscover -r 150.1.7.1



target is available on network range.

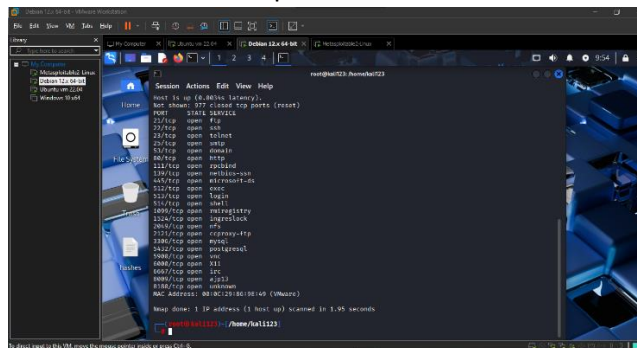
c) ARP Cache Inspection

Commands used: arp -a

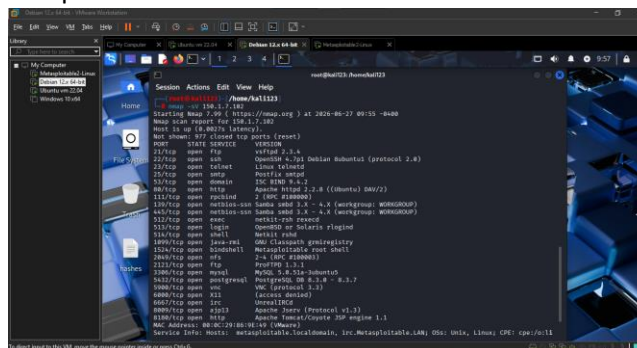
```
(root@kali123)~[/home/kali123]
# ip neigh
150.1.7.100 dev eth1 lladdr 00:50:56:c0:00:01 STALE
150.1.7.1 dev eth1 FAILED
192.168.190.133 dev eth0 lladdr 00:0c:29:bb:a9:e4 REACHABLE
150.1.7.102 dev eth1 lladdr 00:0c:29:86:9e:49 STALE
192.168.190.2 dev eth0 lladdr 00:50:56:ea:eb:c5 REACHABLE
192.168.190.254 dev eth0 lladdr 00:50:56:e6:31:0f STALE
fe80::afd5:a1b8:1be5:5ce1 dev eth1 lladdr 00:50:56:c0:00:01 STALE
```

d) Initial Port Scanning of metasploitable

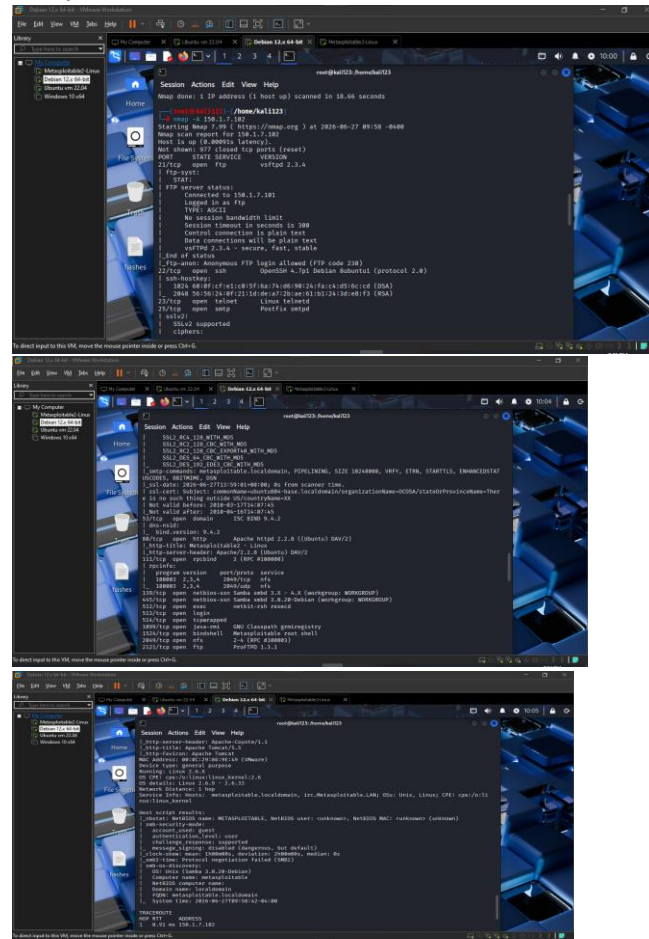
Commands used: nmap -sS 150.1.7.102



nmap -sV 150.1.7.102



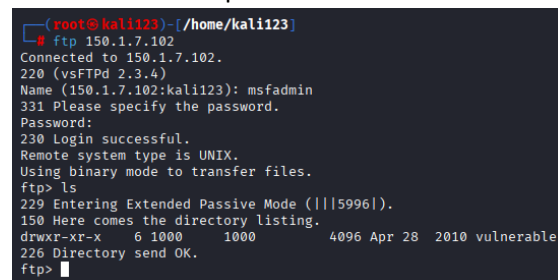
nmap -A 150.1.7.102



6. Enumeration

a) FTP Enumeration (Port 21)

use commands: ftp 150.1.7.102

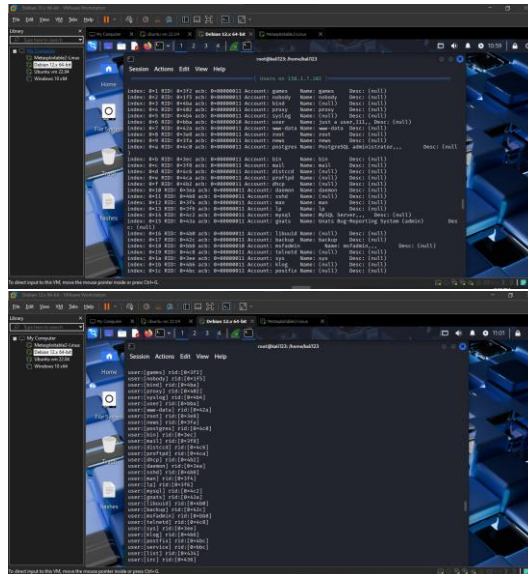


Directory listing and login attempt was successful from ftp port.

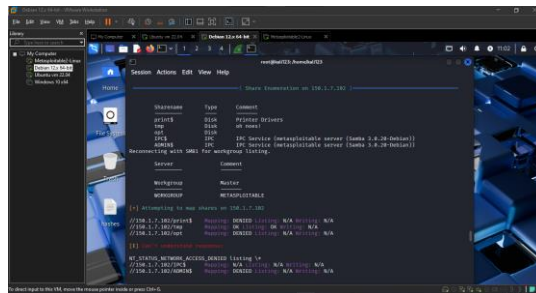
b) SMB Enumeration (Port 139/445)

Command use: enum4linux -a 150.1.7.102

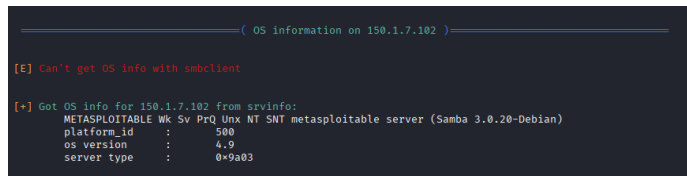
Enumerated Users:



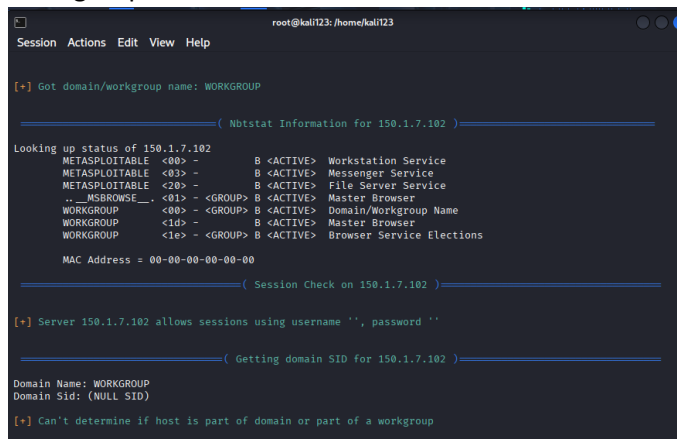
Shared folders:



OS info



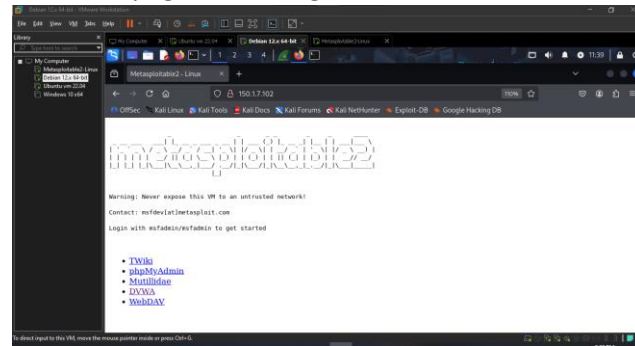
Workgroup info



c) HTTP Enumeration (Port 80)

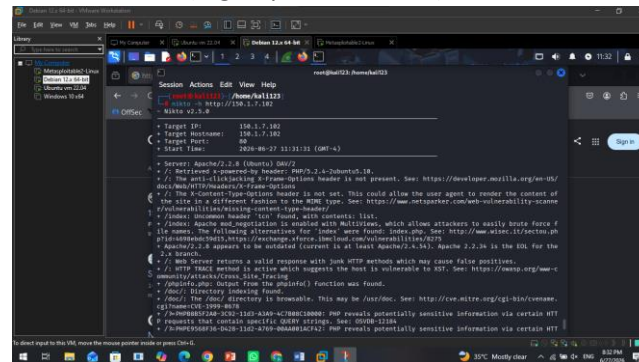
Command used: <http://150.1.7.102> for preview of webpage

The homepage of the target website



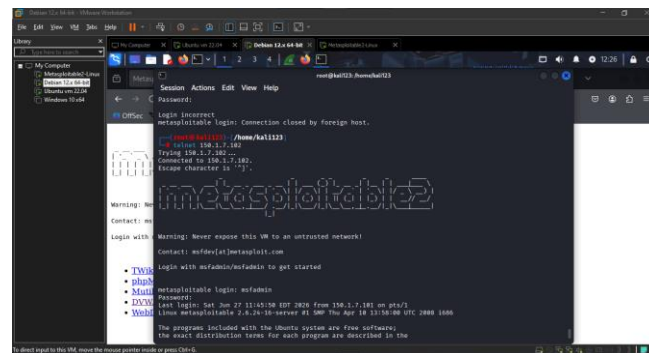
Command used: `nikto -h http://150.1.7.102`

Server banner (e.g., Apache version)



d) Telnet Enumeration (Port 23)

Command used `telnet 150.1.7.102`



7. Post-Enumeration

a) Run an Nmap Vulnerability Scan

Command used: `nmap --script vuln 150.1.7.102`

```
root@kali:~# nmap -sV 150.1.7.102
Nmap scan report for 150.1.7.102
Host is up (0.0029s latency).
Not shown: 977 closed tcp ports (reset)
PORT: 80/tcp
22/tcp open: ssh
|_ftp-vuln-sslv2:
|_VULNERABLE:
|_  ftp-vuln-sslv2 2.3.4 backdoor
|_    State: VULNERABLE (exploitable)
|_    IDS: CVE(CVE-2011-2523) BID:48539
|_    vuln version 2.3.4 backdoor, this was reported on 2011-07-04.
|_    Disclosure date: 2011-07-03
|_    Exploit results:
|_      Shell command: ls
|_      Results: cida@root:~$ cd /root
|_    References:
|_      https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2011-2523
|_      https://github.com/rapid7/metasploit-framework/blob/master/modules/exploits/unix/ftp/vsftpd_234_hack
|_ 00000000
|_ 22/tcp open: ssh
|_ 23/tcp open: telnet
|_ 29/tcp open: smtp
|_  sslv2-drown: ERROR: Script execution failed (use -d to debug)
|_  sslv2-drown:
|_  VULNERABLE:
|_  Anonymous Diffie-Hellman Key Exchange MITM Vulnerability
|_    State: VULNERABLE
|_    Transport Layer Security (TLS) services that use anonymous
|_    Diffie-Hellman key exchange only provide protection against passive
|_    eavesdropping, and are vulnerable to active man-in-the-middle attacks
```

```
root@kali:~# nmap -sV 150.1.7.102
Session Actions Edit View Help
Anonymous Diffie-Hellman Key Exchange MITM Vulnerability
State: VULNERABLE
Transport Layer Security (TLS) services that use anonymous
Diffie-Hellman key exchange only provide protection against passive
eavesdropping, and are vulnerable to active man-in-the-middle attacks
which could completely compromise the confidentiality and integrity
of any data exchanged over the resulting session.
Check results:
ANONYMOUS DH GROUP 1
Cipher Suite: TLS_DH_anon_WITH_RC4_128_MD5
Modulus Type: Safe prime
Modulus Source: postfix builtin
Modulus Length: 1024
Generator Length: 8
Public Key Length: 1024
References:
https://www.ietf.org/rfc/rfc2246.txt
Transport Layer Security (TLS) Protocol DHE_EXPORT Ciphers Downgrade MITM (Logjam)
State: VULNERABLE
IDS: CVE(CVE-2015-4000) BID:74723
The Transport Layer Security (TLS) protocol contains a flaw that is
triggered when handling Diffie-Hellman key exchanges defined with
the DHE_EXPORT cipher. This may allow a man-in-the-middle attacker
to downgrade the security of a TLS session to 512-bit export-grade
cryptography, which is significantly weaker, allowing the attacker
to more easily break the encryption and monitor or tamper with
the encrypted stream.
Disclosure date: 2015-5-19
Check results:
EXPORT-GRADE DH GROUP 1
Cipher Suite: TLS_DHE_RSA_EXPORT_WITH_DES40_CBC_SHA
References:
https://weakdh.org
ssl-poodle:
VULNERABLE:
SSL POODLE information leak
State: VULNERABLE
IDS: CVE(CVE-2014-3566) BID:70574
The SSL protocol 3.0, as used in OpenSSL through 1.0.1i and other
products, uses nondeterministic CBC padding, which makes it easier
for man-in-the-middle attackers to obtain cleartext data via a
padding-oracle attack, aka the "POODLE" issue.
Disclosure date: 2014-10-14
Check results:
TLS_RSA_WITH_AES_128_CBC_SHA
References:
https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2014-3566
https://www.openssl.org/~bodo/ssl-poodle.pdf
https://www.imperialviolet.org/2014/10/14/poodle.html
https://www.securityfocus.com/bid/70574
smtp-vuln-cve2010-4344:
The SMTP server is not Exim: NOT VULNERABLE
53/tcp open: http
80/tcp open: http
http-stored-xss: Couldn't find any stored XSS vulnerabilities.
```

```
root@kali:~# nmap -sV 150.1.7.102
Session Actions Edit View Help
80/tcp open: http
http-stored-xss: Couldn't find any stored XSS vulnerabilities.
http-csrf:
Spidering limited to: maxdepths:3; maxpagecount:20; withinhost:150.1.7.102
Found the following possible CSRF vulnerabilities:
Path: http://150.1.7.102:80/dvwa/
Form id:
Form action: login.php
Path: http://150.1.7.102:80/mutillidae/index.php?page=html5-storage.php
Form id: idform
Form action: index.php?page=html5-storage.php
Path: http://150.1.7.102:80/mutillidae/?page=view-someones-blog.php
Form id: id-bad-blog-entry-tr
Form action: index.php?page=view-someones-blog.php
Path: http://150.1.7.102:80/mutillidae/index.php?page=login.php
Form id: idloginform
Form action: index.php?page=login.php
http-sql-injection: ERROR: Script execution failed (use -d to debug)
http-trace: TRACE is enabled
http-vuln-cve2017-1001000: ERROR: Script execution failed (use -d to debug)
http-dombased-xss: Couldn't find any DOM based XSS.
http-enum:
/cikikiwiki/
/test/: Test page
/phpinfo.php: Possible information file
/phpMyAdmin/: phpMyAdmin
/doc/: Potentially interesting directory w/ listing on 'apache/2.2.8 (ubuntu) dav/2'
/icons/: Potentially interesting folder w/ directory listing
```

```
Session Actions Edit View Help
| /doc/: Potentially interesting directory w/ listing on 'apache/2.2.8 (ubuntu) dav/2'
| /icons/: Potentially interesting folder w/ directory listing
| /index/: Potentially interesting folder
| 131/tcp open rpcbind
| 139/tcp open netbios-ssn
| 445/tcp open microsoft-ds
| 512/tcp open exec
| 513/tcp open login
| 514/tcp open shell
| 1099/tcp open rmiregistry
| rmi-vuln-classloader:
|   VULNERABLE:
|   RMI registry default configuration remote code execution vulnerability
|   State: VULNERABLE
|   Default configuration of RMI registry allows loading classes from remote URLs which can lead to remote code execution.
|   References:
|   https://github.com/rapid7/metasploit-framework/blob/master/modules/exploits/multi/misc/java_rmi_server.rb
| 1324/tcp open ingreslock
| 2049/tcp open nfs
| 2121/tcp open cproxy-ftp
| 3286/tcp open mysql
|   ssl-ccs-injection: No reply from server (TIMEOUT)
| 5432/tcp open postgresql
|   ssl-ccs-injection:
|   VULNERABLE:
|   SSL/TLS MITM vulnerability (CCS Injection)
|   State: VULNERABLE
|   Risk Factor: High
|   OpenSSL before 0.9.8za, 1.0.0 before 1.0.0m, and 1.0.1 before 1.0.1h

root@kali:~#

Session Actions Edit View Help
| Risk Factor: High
| OpenSSL before 0.9.8za, 1.0.0 before 1.0.0m, and 1.0.1 before 1.0.1h
| does not properly restrict processing of ChangeCipherSpec messages,
| which allows man-in-the-middle attackers to trigger use of a zero
| length master key in certain OpenSSL-to-OpenSSL communications, and
| consequently hijack sessions or obtain sensitive information, via
| a crafted TLS handshake, aka the "CCS Injection" vulnerability.
| References:
| http://www.cvedetails.com/cve/2014-0224
| http://www.openssl.org/news/secadv_20140605.txt
| https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2014-0224
| ssl-dh-param:
| VULNERABLE:
| Diffie-Hellman Key Exchange Insufficient Group Strength
| State: VULNERABLE
| Transport Layer Security (TLS) services that use Diffie-Hellman groups
| of insufficient strength, especially those using one of a few commonly
| shared groups, may be susceptible to passive eavesdropping attacks.
| Check results:
| WEAK DH GROUP 1
| Cipher Suite: TLS_DHE_RSA_WITH_AES_128_CBC_SHA
| Modulus Type: Safe prime
| Modulus Source: Unknown/Custom-generated
| Modulus Length: 1024
| Generator Length: 0
| Public Key Length: 1024
| References:
| https://weakdh.org
| ssl-poodle:
| VULNERABLE:
| SSL POODLE information leak

root@kali:~#

Session Actions Edit View Help
| ssl-poodle:
| VULNERABLE:
| SSL POODLE information leak
| State: VULNERABLE
| IDs: CVE:CVE-2014-3566 BID:70574
| The SSL protocol 2.0, as used in OpenSSL through 1.0.1i and other
| products, uses nondeterministic CBC padding, which makes it easier
| for man-in-the-middle attackers to obtain cleartext data via a
| padding-oracle attack, aka the "POODLE" issue.
| Disclosure date: 2014-10-14
| Check results:
| TLS_RSA_WITH_AES_128_CBC_SHA
| References:
| https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2014-3566
| https://www.openssl.org/bugs/ssl-poodle.pdf
| https://www.imperialviolet.org/2014/10/14/poodle.html
| https://www.securityfocus.com/bid/70574
| 5900/tcp open vnc
| 6000/tcp open x11
| 6667/tcp open irc
|   irc-unrealircd-backdoor: Looks like trojaned version of unrealircd. See http://seclists.org/fulldisclosure
| 67030/2m/277
| 8009/tcp open ajp13
| 8180/tcp open unknown
| http-slowloris-check:
| VULNERABLE:
| Slowloris DOS attack
| State: LIKELY VULNERABLE
| IDs: CVE:CVE-2007-6758
| Slowloris tries to keep many connections to the target web server open and hold
| them open as long as possible. It accomplishes this by opening connections to
| the target web server and sending a partial request. By doing so, it starves

root@kali:~#

Session Actions Edit View Help
| JSESSIONID:
| HttpOnly Flag not set
| http-enum:
| /admin/: Possible admin folder
| /admin/index.html: Possible admin folder
| /admin/login.html: Possible admin folder
| /admin/admin.html: Possible admin folder
| /admin/account.html: Possible admin folder
| /admin/admin_login.html: Possible admin folder
| /admin/home.html: Possible admin folder
| /admin/admin_login.html: Possible admin folder
| /admin/adminlogin.html: Possible admin folder
| /admin/controlpanel.html: Possible admin folder
| /admin/cp.html: Possible admin folder
| /admin/index.jsp: Possible admin folder
| /admin/login.jsp: Possible admin folder
| /admin/admin.jsp: Possible admin folder
| /admin/home.jsp: Possible admin folder
| /admin/controlpanel.jsp: Possible admin folder
| /admin/admin_login.jsp: Possible admin folder
| /admin/cp.jsp: Possible admin folder
| /admin/account.jsp: Possible admin folder
| /admin/admin_login.jsp: Possible admin folder
| /admin/adminlogin.jsp: Possible admin folder
| /manager/html/upload: Apache Tomcat (401 Unauthorized)
| /manager/html: Apache Tomcat (401 Unauthorized)
| /admin/xview/javascript/fckeditor/editor/filemanager/connectors/test.html: OpenCart/FCKeditor File Upload
| /admin/includes/FCKeditor/editor/filemanager/upload/test.html: ASP Simple Blog / FCKeditor File Upload
| /admin/jscript/upload.html: Lizard Cart/Remote File upload
| /webdav/: Potentially interesting folder
| MAC Address: 00:0C:29:86:9E:A9 (VMware)
```

b) Web Server Assessment

Command used: nikto -h <http://150.1.7.102>

- c) Search for Public Exploits
Command used: searchsploit <service_name>
- d) Review Service Versions
- e) Findings Table

8. Findings

The vulnerability assessment and penetration testing exercise identified multiple security weaknesses on the Metasploitable 2 target system. Network reconnaissance revealed numerous open ports exposing services such as FTP, Telnet, HTTP, SMB, SSH, SMTP, and database services. Service enumeration confirmed that several applications were outdated and matched publicly documented vulnerabilities.

Anonymous FTP access was enabled, allowing unauthenticated users to access the FTP service. SMB enumeration disclosed user accounts, shared resources, and operating system information, providing valuable intelligence for potential attackers. The Telnet service accepted remote connections, transmitting authentication data without encryption and increasing the risk of credential compromise. Web server assessment using Nikto identified outdated Apache components, insecure HTTP configurations, and other web server misconfigurations. Vulnerability scanning and public exploit research confirmed that several detected services had known exploits available in public exploit databases. Controlled exploitation within the isolated laboratory environment successfully demonstrated that vulnerable services could be compromised, validating the identified security weaknesses. Post-exploitation activities further confirmed the ability to gather system information and assess the potential impact of a successful attack.

Overall, the assessment demonstrated that the target system contains intentionally vulnerable configurations suitable for security training. In a production environment, these weaknesses would present a significant risk to the confidentiality, integrity, and availability of organizational assets.

9. Risk analysis

The overall risk level of the assessed target is critical due to the presence of multiple high-impact vulnerabilities and insecure services. Several exposed services were running outdated software versions with publicly available exploits, significantly reducing the effort required for an attacker to gain unauthorized access.

The combination of anonymous FTP access, unsecured Telnet communication, vulnerable SMB services, and outdated web server software increases the attack surface and provides multiple paths for compromise. Successful exploitation of these vulnerabilities could result in unauthorized access, information disclosure, privilege escalation, service disruption, and complete system compromise.

Although the assessment was performed within an isolated laboratory environment designed for educational purposes, similar vulnerabilities in a production environment could lead to

severe business impacts, including data breaches, operational downtime, reputational damage, and financial loss. The findings emphasize the importance of timely patch management, secure service configuration, network segmentation, strong authentication mechanisms, and regular vulnerability assessments to reduce organizational risk.

Findings	Severity	Potential Impact	Risk Level
Anonymous Ftp Access	Medium	Unauthorized File Access	Medium
Telnet Service Enabled	High	Credential Interception	High
Outdated Apache Web Server	High	Remote Exploitation	High
Smb Information Disclosure	High	User And System Enumeration	High
Publicly Available Service Exploits	Critical	Remote Code Execution	Critical
Multiple Open Network Services	Medium	Increased Attack Surface	Medium